



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Incidentes de Ciberseguridad

TEMA 5

Detección y Documentación de Incidentes de Ciberseguridad
Alberto Diéguez Álvarez

Descripción de la tarea.	3
Blue Team (Let's defend)	3
Introducción: caso práctico (contexto, alerta inicial Y primeras investigaciones).	3
Actividad principal: comunicaciones, notificación y gestión del incidente según la guía nacional de notificación y gestión de ciber incidentes presente en la documentación de la unidad.	6
1. Clasificación justificada del incidente (taxonomía oficial):	6
2. Determinación del nivel de peligrosidad:	7
3. Determinación del nivel de impacto:	7
4. Obligación de notificar al CSIRT correspondiente.	8
5. Tabla de información a enviar al CSIRT (plantilla a completar).	9
6. Notificaciones requeridas y frecuencia.	11
7. Estado de cierre del incidente.	13

Descripción de la tarea.

Blue Team (Let's defend)



INCIBE. Ventanillas Únicas ([CCO](#))

El equipo azul (blue team) en ciberseguridad se refiere a un equipo dedicado a la defensa de una organización contra posibles amenazas de seguridad cibernética. El blue team lleva a cabo actividades como la detección y respuesta a incidentes, la evaluación continua de la seguridad y la implementación de medidas de seguridad proactivas para prevenir futuros ataques. El objetivo del blue team es proteger los sistemas y datos de la organización, manteniendo un alto nivel de seguridad y disponibilidad.

La web "<https://letsdefend.io/>" es una plataforma que ofrece soluciones y servicios en el ámbito de la ciberseguridad, como la formación y el entrenamiento en habilidades técnicas para la defensa cibernética, así como pruebas de penetración y evaluaciones de seguridad para empresas y organizaciones.

¿Qué te pedimos que hagas?

Introducción: caso práctico (contexto, alerta inicial Y primeras investigaciones).

“Eres parte del equipo de ciberseguridad (SOC) de la sede del Ministerio de Justicia en Andalucía. Un día recibes una llamada urgente del responsable de TI: se han detectado eventos anómalos en un servidor corporativo y existe la sospecha de un ataque web en curso contra un servicio interno crítico (portal documental).

Al revisar el SIEM, aparece una alerta ‘Critical’ asociada a un posible intento de explotación de vulnerabilidad sobre un servidor on-premise de SharePoint. Tu misión como analista SOC es clasificar el posible incidente, valorar peligrosidad e impacto y documentar las comunicaciones/notificaciones necesarias siguiendo la Guía Nacional de Notificación y Gestión de Ciberincidentes.”

Evidencia inicial: alerta SIEM:

Tabla A — Detalle del evento

Severidad	Critical
Fecha / hora	Jul 22, 2025 – 01:07 PM
Rule name	SOC342 – CVE-2025-53770 SharePoint “ToolShell” Auth Bypass and RCE
EventID	320
Tipo	Web Attack
Hostname	SharePoint01
Source IP	107.191.58.76
Destinatio n IP	172.16.20.17
HTTP method	POST
Requested URL	/_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.a spx
User- Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:120.0) Gecko/20100101 Firefox/120.0
Referer	/_layouts/SignOut.aspx
Content- Length	7699
Motivo del disparo	POST no autenticado a ToolPane.aspx, payload grande y referer “spoofed”, indicativo de explotación CVE-2025-53770.

Evolución de la investigación: primeras evidencias recopiladas por el SOC

Tras revisar la alerta en el SIEM, el equipo inicia el triaje del evento para confirmar si se trata de un simple intento o de un compromiso real. En los primeros minutos se revisan registros del servidor web, trazas de red y métricas de disponibilidad del servicio. Con esa revisión inicial se obtiene la siguiente información **preliminar** (ficticia), que servirá como base para **clasificar el incidente**, estimar **peligrosidad** e **impacto** y determinar las **comunicaciones y notificaciones** que procedan.

Tabla B — Contexto del organismo y hallazgos iniciales:

Servicio afectado	Portal documental interno (SharePoint) para tramitación y gestión de expedientes
Usuarios	~600 usuarios internos; pico ~300 simultáneos
Criticidad	Servicio importante (impacta la operativa diaria)
Alcance técnico	Granja pequeña: 2 frontales web + 1 SQL + 1 app (SharePoint01 es frontal web)
Evidencias complementarias (SOC)	1) Pico de 120 POST similares desde la misma IP en 6 minutos. 2) Tras el evento, SharePoint01 inicia conexiones salientes HTTPS a 107.191.58.76:443 durante 3 minutos (5 intentos). 3) No hay confirmación de exfiltración, pero sí indicio de posible compromiso de aplicación .
Disponibilidad	Servicio degradado ~70 minutos (errores intermitentes). Afectación estimada ~35% usuarios en ese periodo.
Datos potencialmente expuestos	Documentos con datos personales (DNI, direcciones, resoluciones) de contexto sensible por el ámbito de Justicia (sin clasificar "SECRETO").
Medidas iniciales aplicadas	Bloqueo temporal de IP origen en WAF/Firewall; aislamiento de salida a Internet del frontal SharePoint01; preservación de logs IIS y eventos del sistema.
Estado al inicio	En investigación / no resuelto

Actividad principal: comunicaciones, notificación y gestión del incidente según la guía nacional de notificación y gestión de ciber incidentes presente en la documentación de la unidad.

Elabora un documento con el resultado de tu trabajo, basándote en la **Guía Nacional de Notificación y Gestión de Ciberincidentes** (especialmente apartados 5 y 6). Debes **justificar** todas las decisiones usando los criterios de la guía y las evidencias de las Tablas A y B.

1. Clasificación justificada del incidente (taxonomía oficial):

1. Clasifica el suceso según la taxonomía oficial (elige una clasificación principal).

Leyendo y buscando información en el pdf que se adjunta en la unidad:
https://www.mecd.es/cidead/aulavirtual/pluginfile.php/600775/mod_resource/content/1/guia_nacional_notificacion_gestion_ciberincidentes.pdf

En el apartado 5 (Clasificación/taxonomía de los ciber incidentes), en la tabla de la página 14, elijo: **Intento de intrusión – Explotación de vulnerabilidades conocidas.**

Ya que viendo la descripción de la tarea se ve que hay POST no autenticado a ToolPane.aspx, payload grande y referer “spoofed”, indicativo de explotación CVE-2025-53770.

2. Si aplica, indica clasificaciones secundarias (solo si las evidencias lo respaldan).

Como secundarias diría:

- Compromiso de la información: Pérdida de datos.
- Disponibilidad: Interrupciones.

3. Justifica tu decisión citando qué elementos del caso (Tablas A y B) te llevan a esa clasificación.

Cito los siguientes casos:

- Este es un caso de intento de intrusión: POST no autenticado a ToolPane.aspx, payload grande y referer “spoofed”, indicativo de explotación CVE-2025-53770.
- Este sería de compromiso de la información: 1) Pico de 120 POST similares desde la misma IP en 6 minutos.
- De disponibilidad: Servicio degradado ~70 minutos (errores intermitentes). Afectación estimada ~35% usuarios en ese periodo.

2. Determinación del nivel de peligrosidad:

1. Asigna un nivel: CRÍTICO / MUY ALTO / ALTO / MEDIO / BAJO.

MUY ALTO. El nivel de peligrosidad del ciber incidente. Es el punto 6.1.1 que empieza en la página 18.

2. Justifica tu elección en función de los criterios oficiales de peligrosidad.

Según la tabla de la página 19, criterios de determinación del nivel de peligrosidad de los ciber incidentes. Lo catalogo como MUY ALTO/ALTO ya que en ese nivel esta la clasificación contenido dañino y disponibilidad. Y en el tipo de incidente también se especifica compromiso de aplicaciones (compromiso de la información) e interrupciones (denegación de servicio).

3. Si el suceso encaja en varias tipologías, prioriza la de mayor peligrosidad.

La de mayor peligrosidad sería disponibilidad.

The screenshot displays a document viewer with three pages. Page 18 shows a table of severity levels. Page 19 contains a detailed table titled 'CRITERIOS DE DETERMINACIÓN DEL NIVEL DE PELIGROSIDAD DE LOS CIBERINCIDENTES'. Page 20 shows a user profile for Alberto Dieguez Alvarez.

Nivel	Clasificación	Tipo de incidente
CRÍTICO	Otros	APT
	Código dañino	Distribución de malware
MUY ALTO	Interrupción	Configuración de malware
	Disponibilidad	Robo
ALTO	Contenido abusivo	Sabotaje
	Código dañino	Interrupciones
	Interrupción	Pornografía infantil, contenido sexual o violento inadecuado
	Interrupción	Sistema infectado
	Interrupción	Servidor C&C (Mando y Control)
	Interrupción	Compromiso de aplicaciones
	Interrupción	Compromiso de cuentas con privilegios
	Interrupción	Ataque desconocido
	Disponibilidad	DDoS (Denegación distribuida de servicio)
	Disponibilidad	Acceso no autorizado a información
BAJO	Compromiso de la información	Modificación no autorizada de información
	Fraude	Pérdida de datos

Alberto Dieguez Alvarez

Información Personal

Dirección de correo: a.dieguez.alvarez@gmail.com

Detalles del curso

Perfiles de curso

- Análisis Forense Informático (25-26)
- Bastionado de Redes y Sistemas (25-26)
- Hacking Ético (25-26)

Actividad de accesos

Primer acceso al sitio

miércoles, 13 de noviembre de 2024, 15:15 (1 año 97 días)

Último acceso al sitio

jueves, 19 de febrero de 2026, 02:33 (1)

3. Determinación del nivel de impacto:

1. Asigna un nivel: CRÍTICO / MUY ALTO / ALTO / MEDIO / BAJO / SIN IMPACTO.

ALTO. El nivel de impacto del ciber incidente viene en el punto 6.1.2, en la página 20.

2. Justifica tu elección usando: afectación a usuarios, duración, criticidad del servicio, posible compromiso de información, etc. (Tabla B).

- Afecta al 35 % de usuarios en el apartado de disponibilidad.
- La denegación del servicio duró unos 70 minutos.
- La criticidad del servicio es importante (impacta a la operativa diaria).
- El compromiso de información son los documentos con datos personales (DNI...)
- El estado esta en investigación / no resuelto.

3. Relaciona tu decisión con los criterios oficiales de impacto.

Dado que ha afectado significativamente a la disponibilidad, pero sin interrupción total ya que nos dice errores intermitentes. Y que tampoco está confirmada la sustracción de datos.

4. Obligación de notificar al CSIRT correspondiente.

1. Indica el CSIRT de referencia aplicable para un organismo del sector público y explica el motivo.

Leyendo la guía en la página 5 se especifica el CSIRT.

The screenshot displays a document viewer interface. On the left, a sidebar shows a table of contents with pages 3, 4, 5, and 6. Page 5 is currently selected and shows a list of CSIRTs (Computer Security Incident Response Teams) with their respective competencies. The list includes:

- CCN-CERT**, del Centro Criptológico Nacional del Centro Nacional de Inteligencia, con un ámbito competencial en el Sector Público general, autonómico y local, y sistemas que manejan información clasificada.
- INCIBE-CERT**, del Instituto Nacional de Ciberseguridad de España, con un ámbito competencial en la ciudadanía y el sector privado. Asimismo, INCIBE-CERT es el CERT que presta servicios de respuesta a incidentes a las instituciones afiliadas a RedIRIS, la red académica y de investigación española, en coordinación con el CCN-CERT en lo que se refiere a organismos públicos.
- Centro Nacional de Protección de Infraestructuras y Ciberseguridad (CNPICI)**, con un ámbito competencial en las infraestructuras críticas y operadores críticos, cuyas capacidades de respuesta técnica se materializan a través de los CSIRT de referencia. Es asimismo autoridad competente para aquellos operadores de servicios esenciales que son además críticos, siendo en ese caso la Oficina de Coordinación Cibernética la responsable de la coordinación en los supuestos previstos en el segundo párrafo del artículo 11.2 del Real Decreto-ley 12/2018.
- ESP-DEF-CERT** del Mando Conjunto de Ciberdefensa, con un ámbito competencial en las redes y los sistemas de información y telecomunicaciones de las Fuerzas Armadas, así como aquellas otras redes y sistemas que específicamente se le encomienden y que afecten a la Defensa Nacional, apoyando a los operadores de servicios esenciales y, necesariamente, en aquellos operadores que tengan incidencia en la Defensa Nacional y que reglamentariamente se determinen.

On the right side of the document viewer, there is a user profile for **ALBERTO DIEGUEZ ALVAREZ**. Below the profile picture, there is a button labeled 'Editar perfil'. Under 'Información Personal', the email address is listed as **a.dieguez.alvarez@gmail.com**. Below this, there are sections for 'Detalles del curso' (showing 'Análisis Forense Informático (25-26)', 'Bastionado de Redes y Sistemas (25-26)', 'Hacking Ético (25-26)', and 'Incidentes de Ciberseguridad (25-26)'), 'Informes' (showing 'Sesiones del navegador' and 'Resumen de Calificaciones'), and 'Actividad de accesos' (showing 'Primer acceso al sitio' on 'miércoles, 13 de noviembre de 2024, 15:15 (1 año 97 días)').

Al organismo que correspondería notificar sería al CCN-CERT, del Centro Criptológico Nacional del Centro Nacional de Inteligencia con un ámbito en el Sector Público general y sistemas que manejan información clasificada entre otras.

2. Determina si la notificación es obligatoria o potestativa, en función de peligrosidad/impacto y el ámbito aplicable.

La notificación es obligatoria, ya que la guía obliga la notificación para incidentes ALTO, MUY ALTO o CRÍTICO.

5. Tabla de información a enviar al CSIRT (plantilla a completar).

Rellena la tabla con la información que se remitiría en una notificación inicial (con lo conocido en ese momento), basándote en los campos recomendados por la guía.

Tabla C — Plantilla de notificación al CSIRT (rellenar)

Asunto	Intento de explotación CVE-2025-53770 Sharepoint- nivel MUY ALTO
Organismo notificante	Ministerio de la Justicia en Andalucía
Sector	Sector Público
Fecha y hora del incidente (UTC)	Jul 22, 2025 – 01:07 PM
Fecha y hora de detección (UTC)	Jul 22, 2025 – 01:07 PM
Descripción detallada	Se reciben varios POST no autenticados contra ToolPane.aspx con la sospecha de explotar la vulnerabilidad CVE-2025-53770, con un payload grande y referer 'spoofed'
Recursos tecnológicos afectados (IPs, roles, versiones si se conocen)	Granja pequeña: 2 frontales web + 1 SQL + 1 app (SharePoint01 es frontal web)
Origen del incidente (si se conoce)	Hay conexiones salientes a la siguiente IP 107.191.58.76:443
Taxonomía (clasificación)	Intento de intrusión – Explotación de vulnerabilidad

Nivel de peligrosidad	MUY ALTO
Nivel de impacto	ALTO
Impacto transfronterizo (sí/no + detalle)	NO, no se determinan sistemas afectados fuera del territorio nacional.
Plan de acción / contramedidas aplicadas	Bloqueo IP en WAF/Firewall; aislamiento de salida a internet del frontal SharePoint01; preservación de logs IIS y eventos del sistema
Afectación (usuarios/sistemas/servicio)	Afectación del 35% de usuarios y el servicio ha sido degradado 70 minutos con errores intermitentes.
Medios necesarios (Jornadas-Persona estimadas)	Medios necesarios sería acceso al entorno, y personas estimadas por jornada, unas 2-3 personas 5 jornadas.
Impacto económico estimado (si aplica)	En principio sin impacto.
Extensión geográfica	Andalucía
Daños reputacionales (si aplica)	Daños en la imagen de la sede del Ministerio de Justicia en Andalucía
Adjuntos (logs, capturas, etc.)	Logs IIS, eventos del sistema y extracto de la alerta SIEM
Regulación afectada (ENS/RGPD/NIS/PIC/Otros)	Afecta al ENS (Esquema Nacional de Seguridad) y a RGPD (Reglamento general de protección de datos) si hubiese extracción de datos.
¿Se requiere actuación FFCSE? (sí/no + motivo)	No se requiere actuación de las Fuerzas y Cuerpos de seguridad ya que no hay evidencia clara.

6. Notificaciones requeridas y frecuencia.

1. Indica cuántas notificaciones proceden: inicial, intermedia, final.

Proceden las tres: Inicial, intermedia y final. Se especifican en el apartado siguiente.

2. Especifica los plazos aplicables según la “ventana temporal de reporte” (en función del nivel asignado).

- Inicial: Según se detecta el incidente, se clasifica e inmediatamente se notifica ya que es de riesgo MUY ALTO.
- Intermedia: Desde que se avisa hasta pasadas 72 horas.
- Final: Máximo 40 días.

La comunicación se realizará siempre por escrito mediante el uso de correo electrónico o sistema proporcionado por el CSIRT de referencia del operador, tomando la estructura de la *Tabla 6. Información a notificar en un ciberincidente a la autoridad competente.*

Nivel de peligrosidad o impacto	Notificación inicial	Notificación intermedia	Notificación final
CRÍTICO	Inmediata	24 / 48 horas	20 días
MUY ALTO	Inmediata	72 horas	40 días
ALTO	Inmediata	-	-
MEDIO	-	-	-
BAJO	-	-	-

Tabla 7. Ventana temporal de reporte para sujetos obligados

3. Explica (4–6 líneas) qué tipo de información se actualizaría en una notificación intermedia (no redactar la notificación completa).

Se actualizará por ejemplo el resultado del análisis del ciber incidente. También se procede a confirmar si el sistema ha sido comprometido o no.

En esa ventana de tiempo se actualizaría el alcance real que ha tenido, nombrando todo lo que esté relacionado como usuarios, sistemas...

Se actualizarían las medidas que han sido aplicadas para detener el ataque, además de la revisión del impacto si es que las evidencias van cambiando durante el análisis.

Evolución final del incidente (salto temporal)

Han transcurrido **10 días naturales** desde la detección inicial. Tras las acciones de contención y análisis, el equipo SOC dispone ya de resultados suficientes para **cerrar el incidente**. A continuación, se incluyen los **hallazgos finales** (ficticios) que deberás usar para documentar el cierre y las comunicaciones finales.

Tabla D — Hallazgos finales para el cierre:

Medidas aplicadas	Se aplicó la mitigación/parche recomendado para el vector del incidente y se verificó la versión/configuración del servicio.
Credenciales y accesos	Se rotaron credenciales de servicio y se revisaron permisos y cuentas con acceso a la granja.
Actividad posterior	No se observaron nuevos intentos con el mismo patrón (POST al endpoint afectado) desde el exterior tras el bloqueo inicial.
Persistencia	Revisión de integridad (archivos, tareas programadas, servicios) sin evidencias claras de persistencia.
Exfiltración	No hay evidencia confirmada de exfiltración (sin picos de salida sostenidos ni artefactos concluyentes). No obstante, no puede descartarse al 100% acceso a contenido durante la ventana inicial.
Disponibilidad	El servicio se mantiene estable desde hace 9 días (sin degradación ni incidencias relacionadas).

7. Estado de cierre del incidente.

1. A partir de los hallazgos finales (Tabla D), indica el estado del cierre del incidente identificando su tipo de cierre correspondiente.

El tipo de cierre es Cerrado (Resuelto con respuesta). Se aplicó un parche además de otras medidas y el servicio lleva 9 días estable.

The screenshot displays a web application interface. On the left, a sidebar shows a document titled 'Guía nacional de notifica...' with page 28 of 55 selected. The main content area shows section '6.6. ESTADOS Y VALORES DE CIERRE'. It includes a paragraph explaining the incident management process and a table with incident states and their descriptions.

Estado	Descripción
Cerrado (Resuelto y sin respuesta)	No hay respuesta por parte del organismo afectado en un periodo determinado. No obstante, el incidente parece estar resuelto.
Cerrado (Resuelto y con respuesta)	El organismo afectado ha solventado la amenaza y notifica a su CSIRT de referencia el cierre del ciberincidente.
Cerrado (Sin impacto)	La detección ha resultado positiva pero el organismo no es vulnerable o no se ve afectado por el ciberincidente.
Cerrado (Falso positivo)	La detección ha sido errónea.
Cerrado (Sin resolución y sin respuesta)	Si el ciberincidente no ha sido resuelto por el organismo afectado y este no ha comunicado con el CSIRT de referencia, es cerrado con este estado.
Cerrado (Sin resolución y con respuesta)	No se ha alcanzado una solución al problema o el afectado indica que no sabe solventarlo incluso con las indicaciones proporcionadas por el CSIRT.
Abierto	Estado que va desde que el organismo afectado notifica la amenaza al CSIRT de referencia, o bien este último lo comunica al afectado, hasta que se produce el cierre del mismo por alguna de las causas anteriormente descritas.

La Tabla 9. Tiempos de cierre del ciberincidente sin respuesta muestra los días tras los que se cerrará un ciberincidente sin respuesta, en función de su nivel de peligrosidad o impacto.

On the right, a user profile for 'ALBERTO DIEGUEZ ALVAREZ' is shown, including a profile picture, a 'Editar perfil' button, and sections for 'Información Personal' (email: a.dieguez.alvarez@gmail.com), 'Detalles del curso' (listing various cybersecurity courses), and 'Informes' (listing navigation sessions and qualification summaries).

2. Justifica el tipo de cierre elegido con evidencias del caso (Tablas A, B y D) y con los criterios de la guía.

Se cierra como 'Resuelto' porque según la guía se cumple la contención, erradicación y la recuperación sin brecha confirmada.

Tablas A y B:

- Hubo intento de explotación con POST no autenticado a ToolPane.aspx, payload grande y referer "spoofed", indicativo de explotación CVE-2025-53770.
- Hubo conexiones salientes HTTPS a 107.191.58.76:443 con indicios de compromiso de aplicación.
- Servicio degradado 70 minutos.
- No hubo confirmación de robo de datos.

Con estas evidencias el incidente de abrió con nivel MUY ALTO.

Tabla D:

- Se aplica parche.
- Se rotan credenciales.
- No hay nuevos intentos.
- Se confirma la no substracción de datos.
- No se detecta persistencia.
- El servicio lleva estable 9 días.

La Tabla 8. Estados de los ciber incidentes de la guía, determina que un incidente puede cerrarse y marcarlo como resuelto cuando:

- Se corrige la vulnerabilidad
- Ya no hay actividad maliciosa
- No hay indicios de persistencia de la vulnerabilidad
- El servicio recupera el funcionamiento normal

Con toda esta información el incidente se cierra y se marca como Cerrado (Resuelto y con respuesta) porque el incidente existió, tubo impacto en el sistema, pero el servicio lleva estable 9 días, no hay persistencia...

Webgrafía:

- https://www.mecd.es/cidead/aulavirtual/pluginfile.php/600865/mod_resource/content/19/IC05_Tarea/GNNGC.pdf
- <https://www.youtube.com/playlist?list=PLgLVwK69OPbzhVi4XEKqeJ19jBQSV1X1I>
- <https://www.youtube.com/watch?v=7QTZuj3i5pA>